

CAN 304

Computer Systems Security

Tutorial 5. Breaking and Fixing Security Protocols

Week 5: 2026-04-02, 14:00-15:00, Thursday

Jie Zhang
Department of Communications and Networking
Email: jie.zhang01@xjtlu.edu.cn
Office: EE522

Question 1

Perfect forward secrecy (PFS) is a security property protecting future compromise. A secure communication system with PFS prevents hackers from decrypting data from other sessions, past or future, even if the secret keys used in an individual session are stolen at some point. The following protocol intends achieve PFS for message exchange between a client and a server by establishing fresh share keys for each message:

1. client $\rightarrow$ server: g^{x_1}
 2. server $\rightarrow$ client: g^{y_1}
 3. client $\rightarrow$ server: $g^{x_2}, E(M_1, k_{11})$
 4. server $\rightarrow$ client: $g^{y_2}, E(M_2, k_{21})$
- $\vdots$

where x_i is generated and kept secretly by client, y_i is generated and kept secretly by server, $k_{ij} = H(g^{x_i y_j})$, H is a hash function with 128-bit output, and $E(M, k)$ denotes encryption of message M using symmetric encryption scheme such as AES using secret key k .

However, the protocol is vulnerable to man-in-the-middle attacks.

- a. Explain in your own words what is a man-in-the-middle attack and why it can happen. **(8 points)**
- b. Illustrate a man-in-the-middle attack to the protocol. **(12 points)**
- c. Propose and detail your method to fix the problem. Hint: your method could be based on some reasonable assumptions such as pre-shared long-term secret keys, correct public keys distribution among the client and server, etc. **(10 points)**

Question 2

The following protocol is designed for two parties A and B to establish a shared session key with the help of a trusted server S . Initially, A shares a secret key K_{AS} with S , and B shares a secret key K_{BS} with S . When A wants to establish a session key with B , A first sends a request to S . The protocol is given below and is also shown in Fig. 1.

1. $A \rightarrow S: A, B, \{A, B\}_{K_{AS}}$
2. $S \rightarrow A: \{K_{AB}\}_{K_{AS}}, \{K_{AB}\}_{K_{BS}}$
3. $A \rightarrow B: \{K_{AB}\}_{K_{BS}}$

Where A, B and S denote the identities of the two parties and the server, K_{AB} is the established session key for A and B , and $\{M\}_K$ denote the ciphertext when a message M is encrypted under the secret key K .

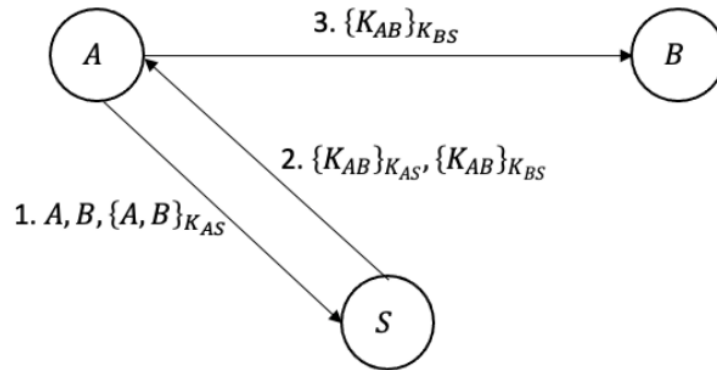


Fig. 1

- a. Explain how A and B can acquire the shared session key through the protocol. **(6 points)**
- b. The protocol has a serious security vulnerability. Let C denote the identity of the attacker, and K_{CS} denote the shared key of C and S . Explain an attack on the protocol where the attacker C establishes shared session keys with A and B while both A and B think they established a shared session key with each other. **(10 points)**
- c. Propose and detail your method to fix the problem. **(14 points)**

Question 3

WhatsApp is an instant messaging (IM) and Voice over IP (VoIP) service owned by technology conglomerate Meta (formerly Facebook). It uses the Extended Triple Diffie-Hellman (X3DH) key agreement protocol to establish shared session keys for users. At registration time, a WhatsApp client transmits its long-term public key, medium public key (signed by long-term private key), and a batch of one-time public keys to the server. Table 4.1 explains the meaning of symbols in the X3DH protocol.

Table 4.1. Symbols in X3DH protocol

Symbol	Notation
A, B, S	The communicating participants and the server.
$(pk_{A1}, sk_{A1}), (pk_{B1}, sk_{B1})$	The long-term key pairs of A, B .
$(pk_{A2}, sk_{A2}), (pk_{B2}, sk_{B2})$	The medium-term key pairs of A, B .
$(pk_{A3}, sk_{A3}), (pk_{B3}, sk_{B3})$	The one-time key pairs of A, B .
g	The generator. For each pair of (pk, sk) , $pk = g^{sk}$.
$\parallel$	The string concatenation operator.

Assume client A and client B have finished registration. That is, their long-term public keys, medium-term public keys, and one-time public keys have been correctly stored in the server. Also, assume that the communications between each client and the server are authenticated. A simplified version of the X3DH protocol from WhatsApp security white paper (2017's version) works as following:

1. A requests the public keys $pk_{B1}, pk_{B2}, pk_{B3}$ of B from S .
2. S returns the public keys $pk_{B1}, pk_{B2}, pk_{B3}$ to A .
3. A generates a one-time key pair (pk_{A3}, sk_{A3}) and computes the shared secret as

$$pk_{B2}^{sk_{A1}} \parallel pk_{B1}^{sk_{A3}} \parallel pk_{B2}^{sk_{A3}} \parallel pk_{B3}^{sk_{A3}}$$

4. A sends to B with its identity and long-term and one-time public keys: A, pk_{A1}, pk_{A3}
 5. B calculates the share secret as:
- a. Complete Step 5 in the protocol. You need to give a formula as in Step 3 to show how the shared secret is calculated by B . (8 points)
 - b. Compare the costs of the simplified X3DH the with basic (EC)DH key agreement protocol. You need to evaluate the communicating cost via the number of messages and the computing cost via the number of exponentiations involved in these protocols, excluding the cost for generating key pairs. (8 points)
 - c. Is the simplified X3DH protocol vulnerable to Man-In-The-Middle (MITM) attacks? If your answer is no, explain your reason; otherwise, illustrate an MITM attack to the protocol. Hint: while the communications between clients and server are authenticated, the communications in the initial session between two clients are not authenticated. (14 points)